

Phishing Analysis Fundamentals

TryHackMe Writeup | Social Engineering Exercise

Course: IKB21403 – Vulnerability Analysis

Topic: Social Engineering (Phishing / Email Analysis)

Platform / Room: TryHackMe – Phishing Analysis Fundamentals (phishingemails1tryoe, v2.2)

Difficulty: Easy

1. Introduction

Phishing is one of the most common social engineering attacks. It uses email to trick a user into revealing credentials, executing malware, or granting access, and a single careless click can give an attacker a foothold inside an organisation. As a defender, the job is to inspect the components of an email and decide whether it is benign or malicious, then gather information to strengthen future defences.

This room covers the building blocks of an email: how an address is structured, how mail is delivered, how to read headers and bodies, how to safely reconstruct attachments, and how to classify the different types of phishing. Below I document my analysis of the three provided samples (email1.eml, email2.txt and email3.eml).

2. The Email Address

An email address has three parts: the username (the recipient's mailbox), the @ symbol (which separates the user from the destination), and the domain (the mail server responsible for that address). Email was popularised in the 1970s on ARPANET by Ray Tomlinson, who introduced the @ symbol. The domain is everything after the @.

Question	Answer
Identify the domain used in hatsalesman@tryhatme.com	tryhatme.com

3. Email Delivery

When an email is sent, SMTP (Simple Mail Transfer Protocol) carries the message from the client to the mail server and between servers. The sending server then uses DNS to look up the recipient domain's mail server (its MX record). Once delivered, the recipient retrieves the message using POP3 (downloads to a single device) or IMAP (keeps mail on the server and syncs across multiple devices). The secure transport ports are SMTP 587, IMAP 993 and POP3 995.

Question	Answer
Which protocol sends an email from a client to a mail server?	SMTP
Which service is used to look up the recipient domain's mail server?	DNS
Bob wants to access his email from multiple devices. Which protocol?	IMAP

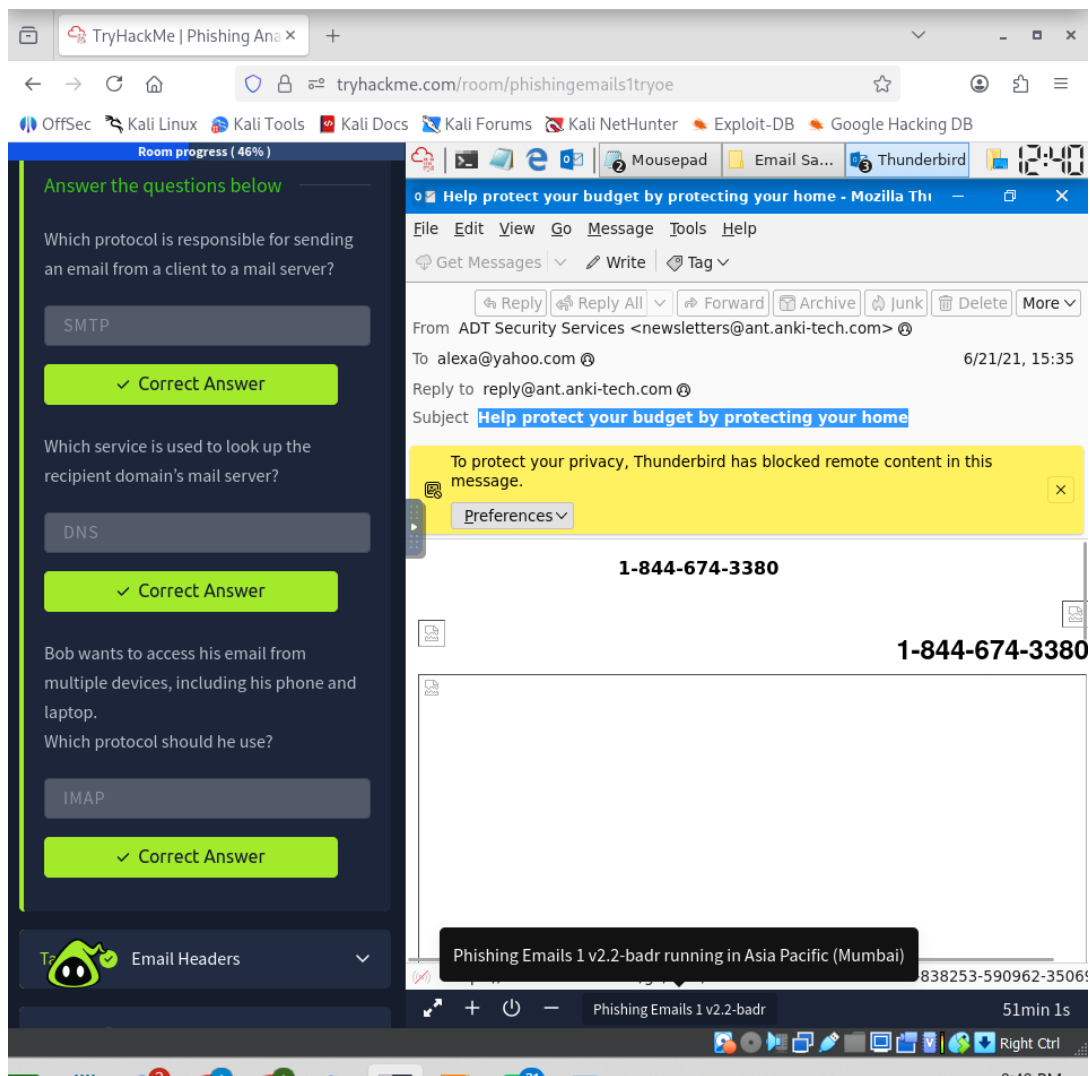


Figure 1: Task 3 – protocol answers (SMTP, DNS, IMAP) accepted, with email1.eml open in Thunderbird.

4. Email Header Analysis – email1.eml

An email has two parts: the header (metadata such as the sender, the servers involved and timestamps) and the body (the actual content). Viewing the raw message source in Thunderbird (View → Message Source, or Ctrl+U) exposes the full header. The most useful fields are From, Return-Path, Reply-To, the Received chain (read bottom to top to find the true origin), X-Originating-Ip, and Authentication-Results.

Sample email1.eml is from “ADT Security Services” <newsletters@ant.anki-tech.com>, with an originating IP of 43.255.56.161. Critically, SPF, DKIM and DMARC all pass, which means the message genuinely originates from ant.anki-tech.com and is not spoofed – it is a legitimate (benign) marketing newsletter rather than a phishing attempt.

Question	Answer
What is the full subject line of email1.eml?	Help protect your budget by protecting your home

Question	Answer
What is the IP listed as the X-Originating-Ip?	43.255.56.161

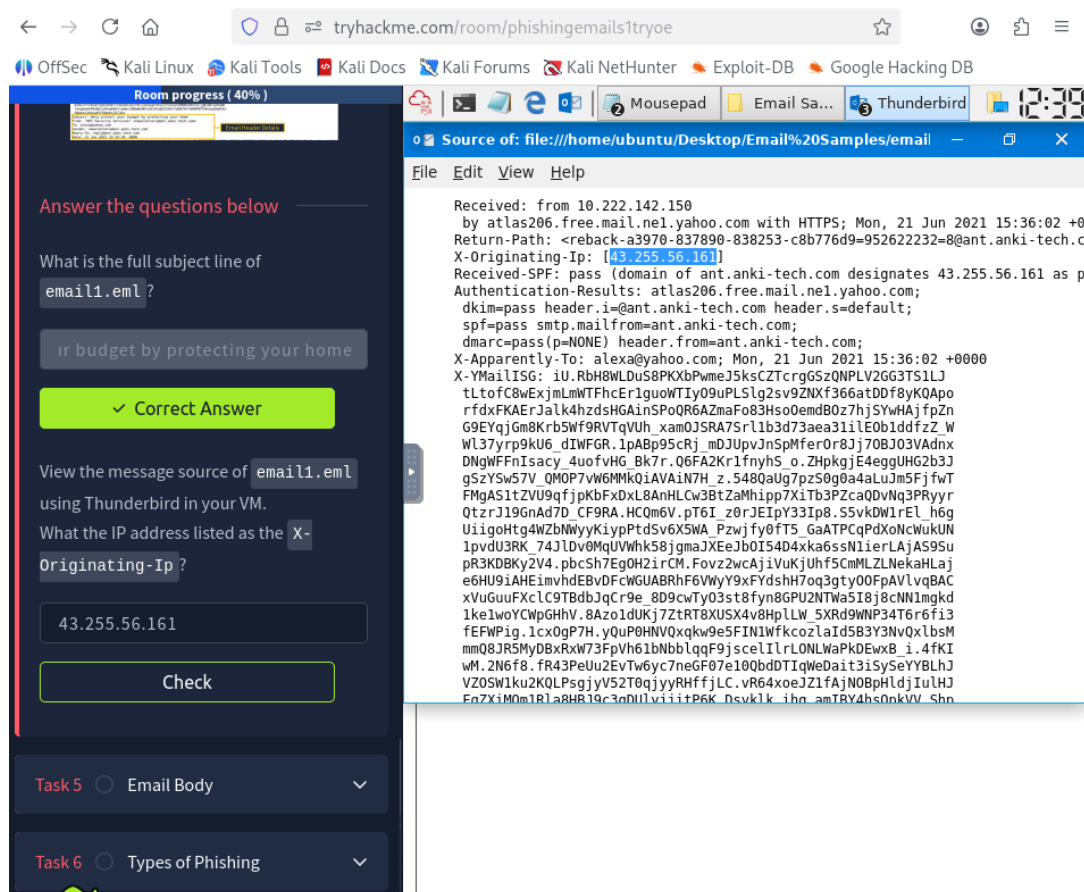


Figure 2: Task 4 – email1.eml message source showing the X-Originating-Ip (43.255.56.161) and SPF/DKIM/DMARC all passing.

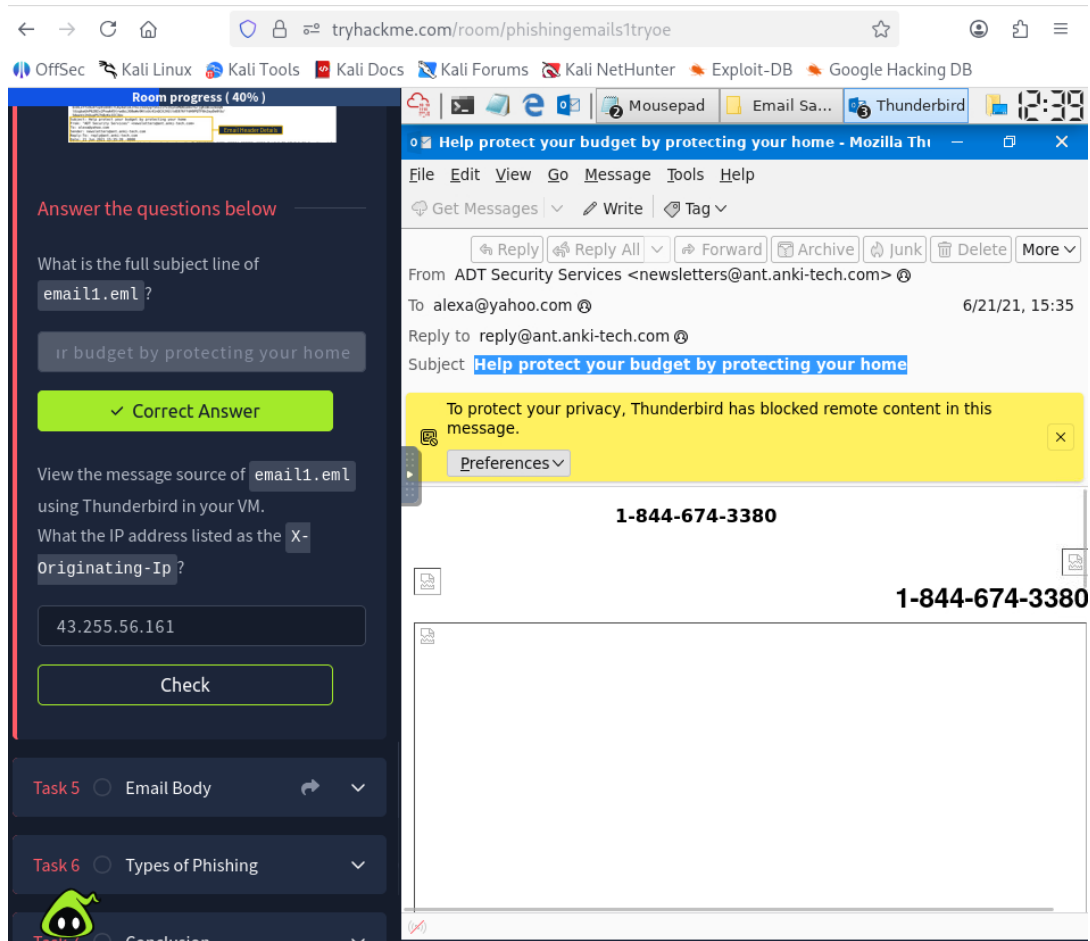


Figure 3: Task 4 – rendered view of email1.eml confirming the subject line and IP answers.

5. Email Body & Attachment Reconstruction – email2.txt

The body of an email may be plain text or HTML, and inspecting the raw source reveals embedded links and images that the rendered view can hide. Attachments are embedded inside the source too and are described by Content-Type (file type), Content-Disposition (attachment + filename) and Content-Transfer-Encoding (here, base64). The base64 block is the file itself and can be decoded to reconstruct the attachment using CyberChef or a base64-to-PDF tool – a safe way to analyse a file without opening it.

In email2.txt the attachment is a PDF: the Content-Type is application/pdf and the filename is zmqpalgh.pdf. Decoding the base64 reconstructs the PDF, which contains the flag THM{BENIGN_PDF_ATTACHMENT}, confirming that this attachment is benign.

Question	Answer
What is the Content-Type of the attachment?	application/pdf
What is the name of the attachment?	zmqpalgh.pdf
What is the hidden flag value inside the decoded PDF?	THM{BENIGN_PDF_ATTACHMENT}

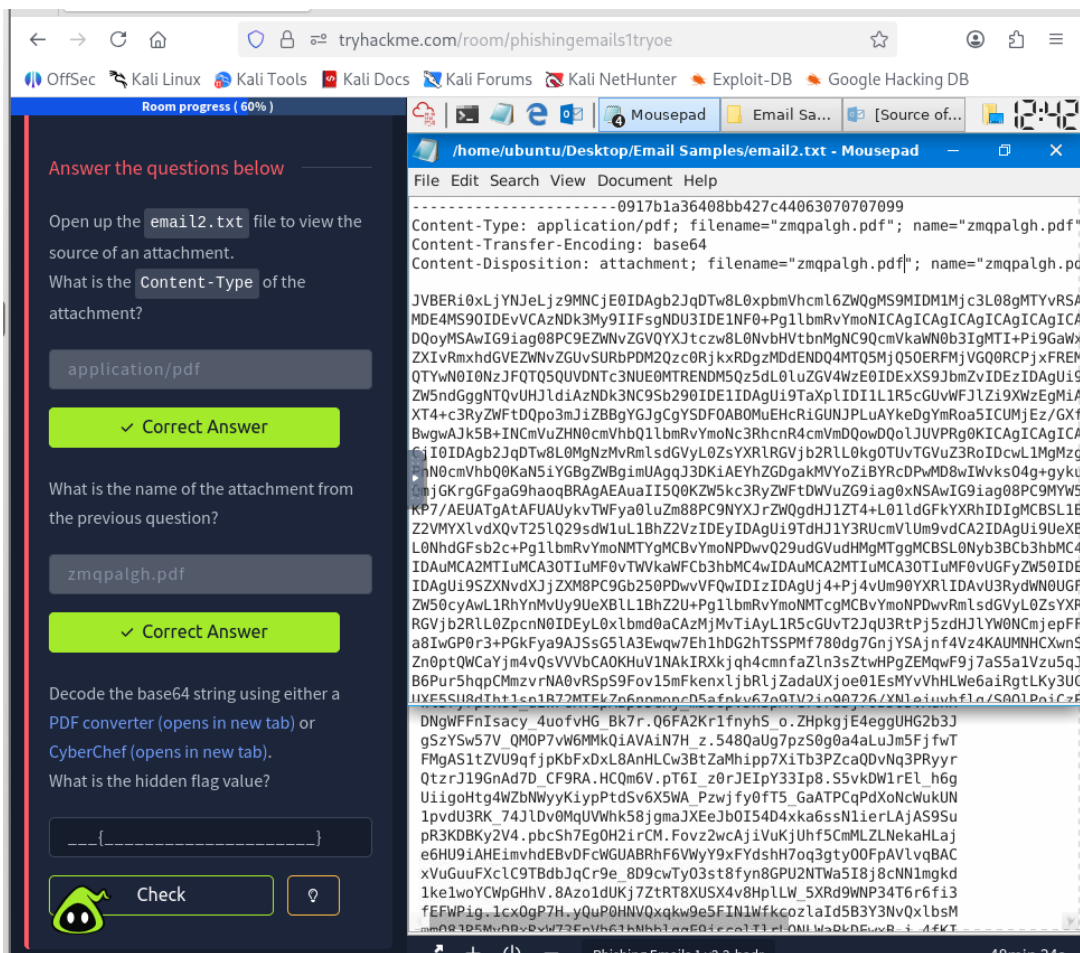


Figure 5: Task 5 – Content-Type (*application/pdf*) and attachment name (*zmqpalth.pdf*) accepted.

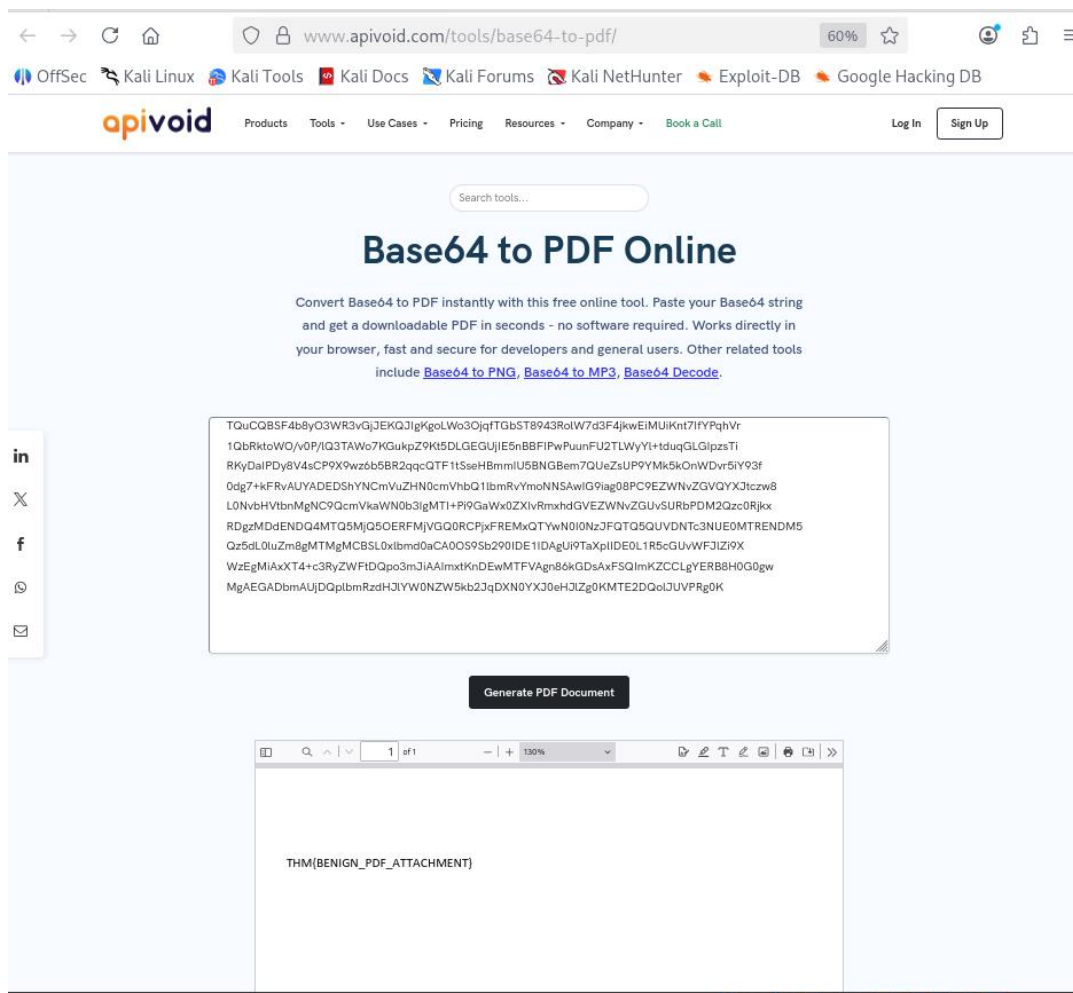


Figure 6: Task 5 – decoding the base64 to a PDF reveals the hidden flag `THM{BENIGN_PDF_ATTACHMENT}`.

6. Types of Phishing & Investigation – email3.eml

Malicious email is generally classified as Spam / MalSpam, Phishing, Spear phishing (targeted), Whaling (targets executives), Smishing (delivered by SMS) and Vishing (carried out by voice call). Common red flags include a spoofed From address, urgent wording, brand impersonation, generic greetings, hidden or shortened links, and malicious attachments. Suspicious links and IPs should be defanged – for example replacing each . with [.] – so they cannot be clicked by accident.

Investigating email3.eml shows it impersonates Home Depot, confirmed by decoding an embedded base64 string that reads “Thank you! Home Depot”. The sender address is support@teckbe.com and the originating IP is 103.234.236.83, which defanged becomes 103[.]234[.]236[.]83. The Authentication-Results header was generated by the receiving Yahoo mail server atlas102.free.mail.gq1.yahoo.com.

Question	Answer
Which reputable organization is being spoofed?	Home Depot

Question	Answer
What is the sender's email address?	support@teckbe.com
What is the defanged X-Originating-IP?	103[.]234[.]236[.]83
Which mail server generated the Authentication-Results header?	atlas102.free.mail.gq1.yahoo.com

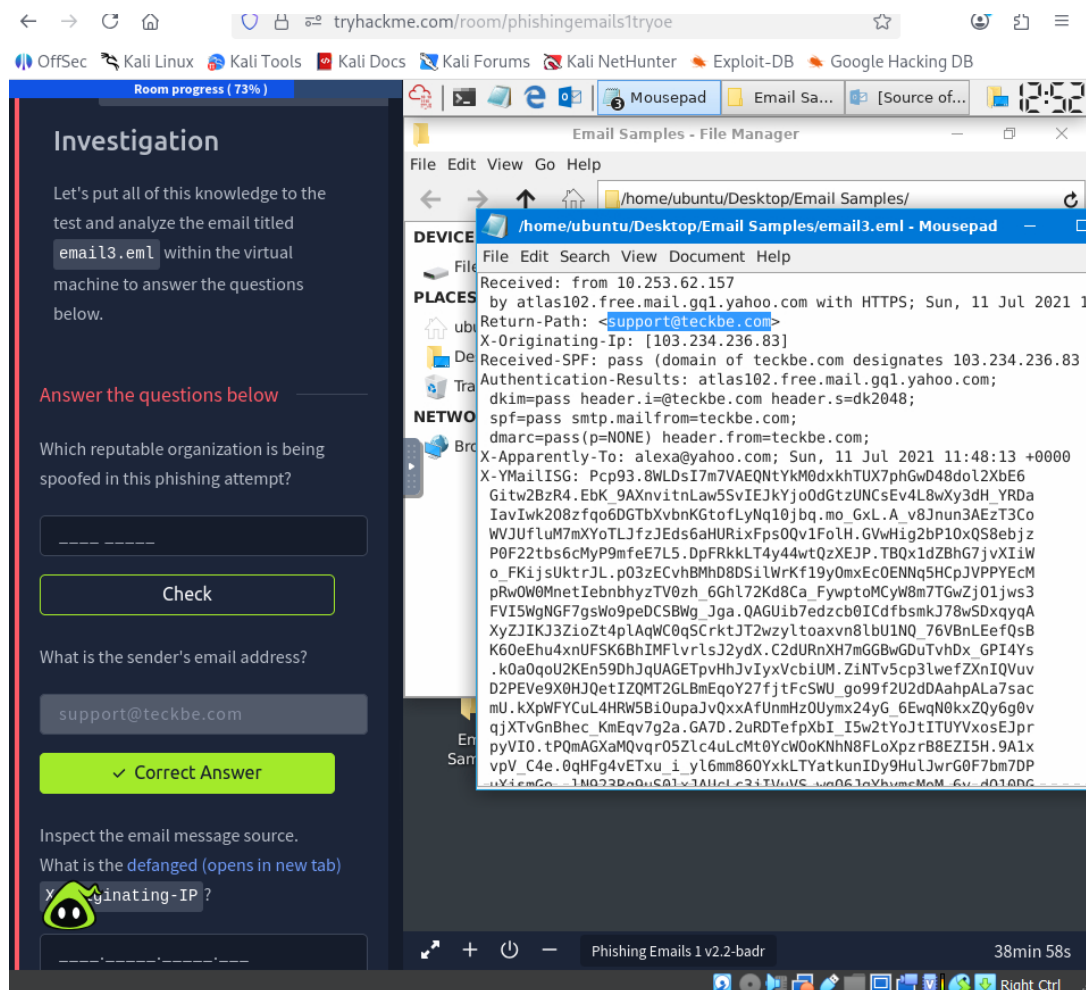


Figure 7: Task 6 – `email3.eml` source showing Return-Path (`support@teckbe.com`), X-Originating-Ip and Authentication-Results.

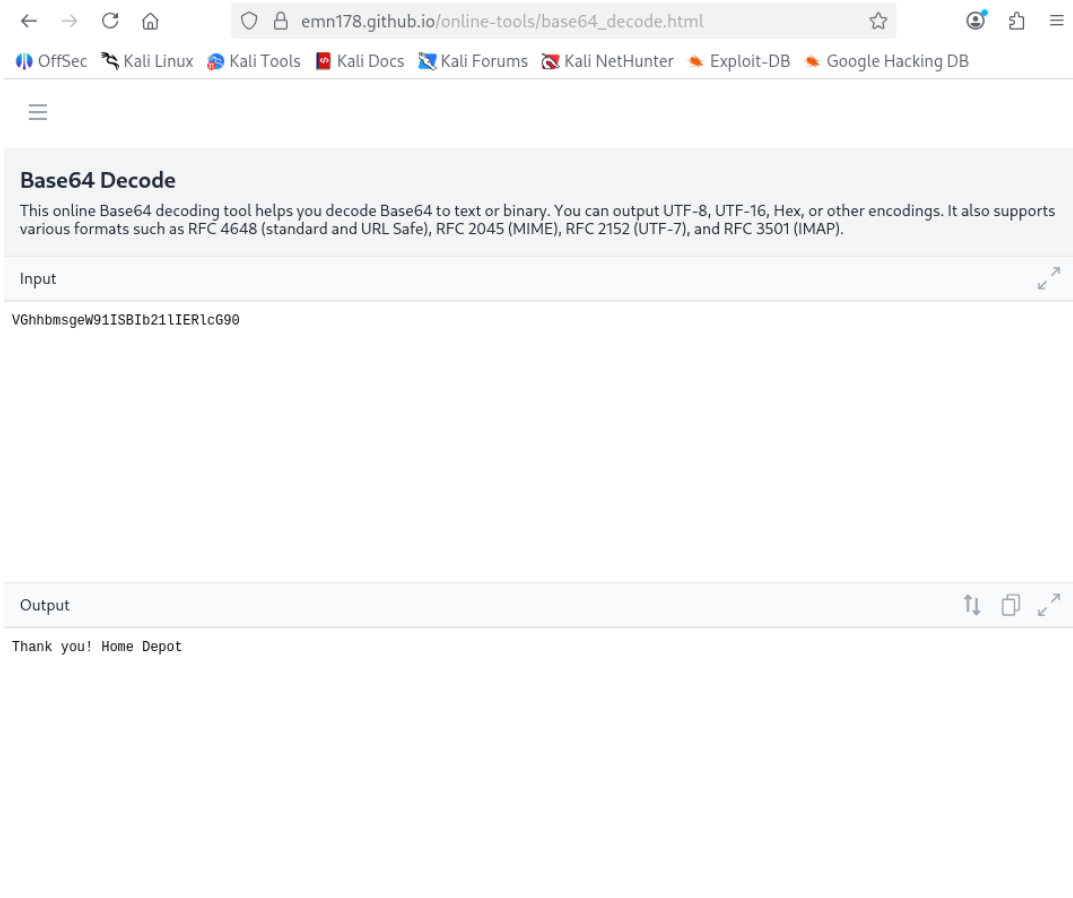


Figure 8: Task 6 – decoding the embedded base64 string reveals the impersonated brand: “Thank you! Home Depot”.

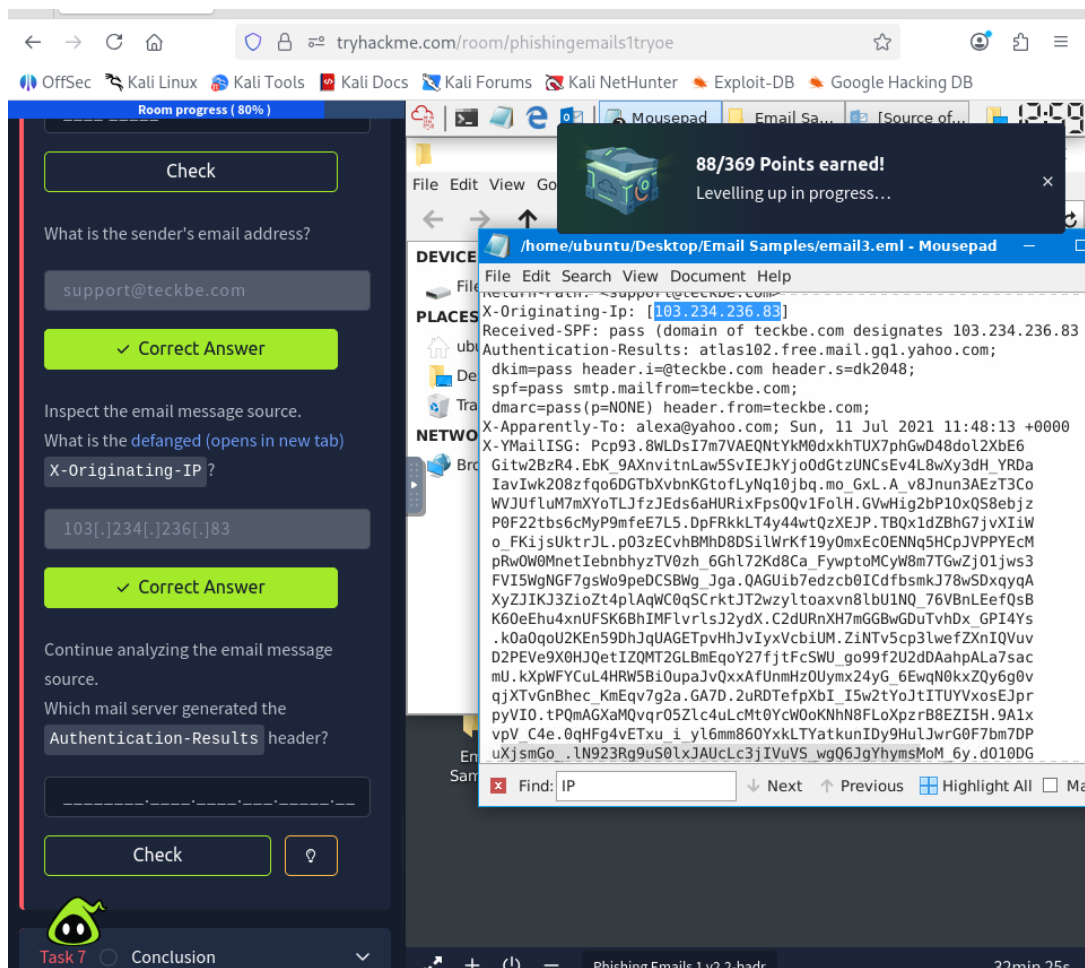


Figure 9: Task 6 – sender address and defanged X-Originating-IP (103[.]234[.]236[.]83) accepted.

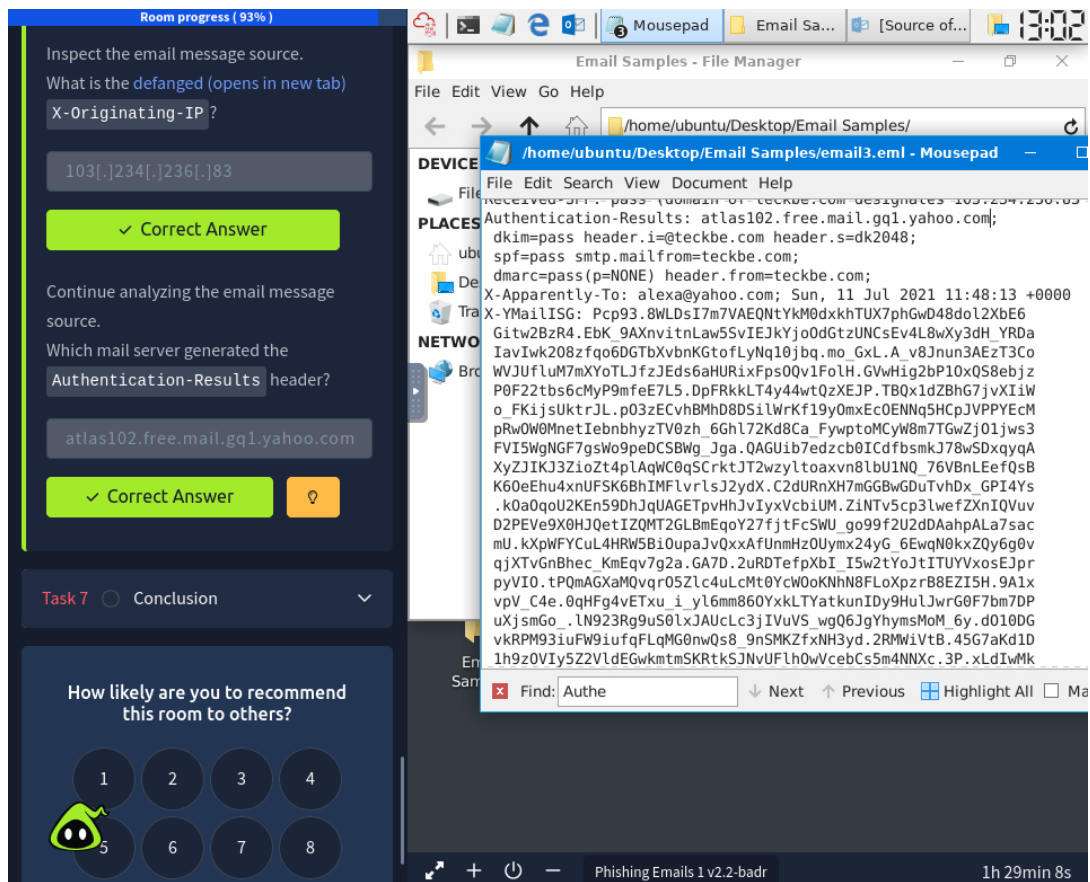


Figure 10: Task 6 – the mail server that generated the Authentication-Results header (atlas102.free.mail.gq1.yahoo.com).

7. Conclusion

This room covered the full anatomy of an email – address structure, delivery protocols, header and body analysis, attachment reconstruction, and phishing classification. The key defensive skill is reading the headers and authentication results to separate legitimate mail (the benign ADT newsletter) from spoofed messages (the Home Depot impersonation), and always handling suspicious links and IPs in defanged form. The room also introduced Business Email Compromise (BEC), where an adversary takes over a legitimate internal email account to defraud others.

Question	Answer
What attack, signified by the acronym BEC, uses a compromised email to trick employees into fraud?	Business Email Compromise

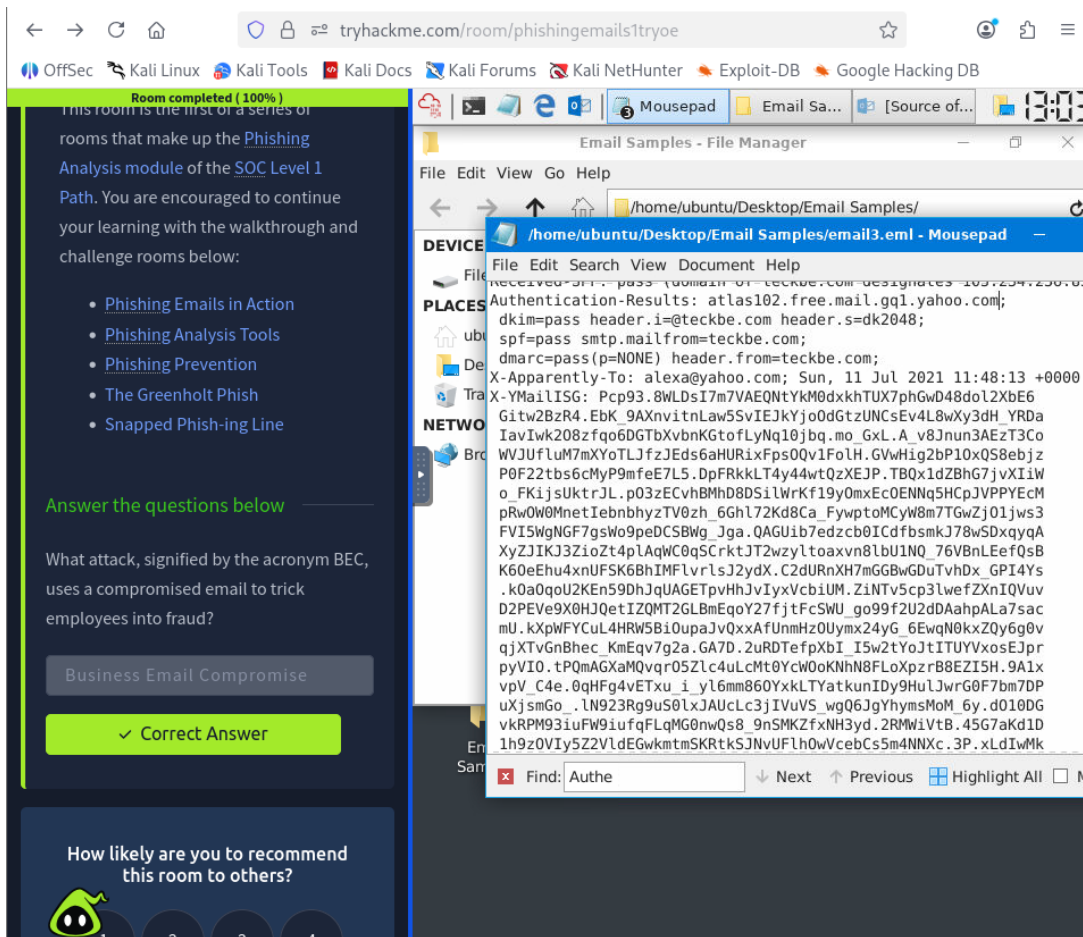


Figure 11: Task 7 – BEC answer accepted and the room completed (100%).